

(Optional) Advanced NGINX Configuration

Security headers

```
add_header X-Frame-Options "SAMEORIGIN" always;  
add_header X-Content-Type-Options "nosniff" always;
```

- X-Frame-Options: SAMEORIGIN
 - Prevents your site from being embedded in an `iframe` by other domains
 - Mitigates clickjacking attacks
- X-Content-Type-Options: nosniff
 - Tells browsers not to “sniff” content types
 - Enforces correct Content-Type
 - Prevents MIME type confusion and XSS
- always
 - Ensures headers are sent on all responses (even 404, 500)

Static files optimization

```
location ~* \.(css|js|png|jpg|jpeg|gif|ico|svg)$ {  
    expires 1y;  
    add_header Cache-Control "public, immutable";  
}
```

- NGINX Cache Control for Static Assets
 - `location ~* .(…)$` — Matches static file types (case-insensitive)
 - `expires 1y` — Sets Expires header to 1 year in the future
 - `add_header Cache-Control "public, immutable":`
 - `public`: Allows caching by any cache (CDN, browser, etc.)
 - `immutable`: Tells the browser the file won't change, so skip revalidation

- Result

- Faster page loads
- Reduced server load
- Ideal for versioned assets like
app.abc123.js

PHP processing

```
location ~ /\.php$ {  
    try_files $uri =404;  
    fastcgi_pass 127.0.0.1:9000;  
    fastcgi_index index.php;  
    fastcgi_param SCRIPT_FILENAME $document_root$fastcgi_script_name;  
    include fastcgi_params;  
}
```

- Used to connect NGINX with PHP-FPM for executing PHP scripts
 - `location ~ .php$` — Matches all .php files
 - `try_files $uri =404` — Returns 404 if the file doesn't exist
 - `fastcgi_pass 127.0.0.1:9000` — Sends the request to PHP-FPM over FastCGI
 - `fastcgi_index index.php` — Default file if directory is requested
 - `fastcgi_param SCRIPT_FILENAME ...` — Tells PHP-FPM the script's full path

API routing

```
location /api/ {  
    try_files $uri $uri/ /api/index.php?$query_string;  
}
```

- Common in PHP frameworks (e.g., Laravel) for handling API routes via a single front controller.
 - location `/api/` — Matches any request starting with `/api/`
 - `try_files $uri $uri/ ...` — Tries to serve a real file or folder
 - `/api/index.php?$query_string` — Fallback if not found:
 - Internally rewrites the request to `index.php`
 - Appends original query string (`$query_string`)

Deny access to hidden files

```
location ~ /\. {  
    deny all;  
}
```

- Blocks any path starting with a dot, e.g. `.env`, `.git`
- **Caution:** this also blocks `/.well-known/`, which is required for HTTPS certificate issuance (e.g., Let's Encrypt). Add an exception if you plan to set up HTTPS later:

```
location ^~ /.well-known/acme-challenge/ {  
    allow all;  
}
```